

Zero Trust Architecture for IoT Devices

Colin, Sudip, CB, SK, Barber, Koirala

Department of Computer Science and Information Systems, Texas A&M-Commerce, May 8, 2022

Abstract

This is a research paper on how to implement zero trust architecture. This paper will explore what zero trust architecture is as it pertains to the context of security for a system of networks. Along with a methodology of zero trust access control with the necessary tools needed for the infrastructure to achieve zero trust such as RBAC, VPM, and or firewalls along with why zero trust networks provide proper security that can scale and implement new elements such as additional devices or software. This document gives an abstract overview of Zero Trust architecture as well as proof of concept.

1. Background

A computer network is created to share resources by implementing three main triads: confidentiality, integrity and availability. Perimeter security is one of the models which works on these three principles. Perimeter security was one of the main network architectures which allows a network to safeguard data and resources by creating a barrier across the network. Use of firewalls and browser isolation systems to have threat recognition, surveillance and act accordingly. A perimeter security is secure if all the devices are registered in the network. However, if devices outside the perimeter or outside the physical network try to access the network, then it gets complex to monitor them as the unknown devices get blocked in the perimeter. With increase in demand for hybrid infrastructure for enterprise networks, it is difficult to create a perimeter and trust the devices trying to access the network. If an attacker joins a perimeter secured network, then they could laterally move across devices in that network. A zero-trust network creates a software defined perimeter at each OSI model layer to hide all the assets. A software defined perimeter checks every single packet to create trust through control and data plane. Implementing zero trust architecture prevents lateral movement by implementing a security principle of not trusting any device or an application by authentication them.

Keywords

Software Defined Perimeter (SDP), Zero Trust Network (ZTN), architecture, Network security

2. Introduction

It should be noted that, trust in the context of cybersecurity is an ideal of certain parameters as data integrity, or confidentiality should not be violated, nor should vulnerabilities be introduced to a system with the implementation of devices or software. With security and safety of a network not being compromised, a device or software should or deserves to be trusted. Therefore, correct evaluation or creation of a secured network that will be trusted with current or newly added properties becomes an issue to be solved. That is the task to be discussed in the paper, and how Zero Trust Architecture provides a solution to this issue.

In simple words, zero trust means to trust no one, verify everything and assume the worst. Much like the term in the justice department accent until proven guilty, zero trust takes the reverse guilty until proven accent, hence the name zero trust. With no trust, every access requested on the network is fully authenticated, authorized, and then encrypted before access is granted. Even after the device is connected to the network, the session is evaluated. The principles are as follows, verify explicitly, use least privileged access, and assume a breach or threat. The basic theory of security is that if a system is secure through start-up, secure in process and ends securely then that system is secure. Zero trust implies the basic concept of no trust in the network so that the network can be securely accessed. Least privileged allows only the necessary principles to access the network. Along with these security principles, a continuous log and analysis of user traffic is done to defend against suspicious intentions.

Zero Trust Architecture is giving implicit trust, generating a system of networks and flow with policies close to the core resources. There is no blanket access granted in this architecture, which means that there are multiple security mechanisms or policies inside the layers of the network. Concurrently, validation of identity is key to give access into the network, as zero trust does not inherently trust components already in the network. This means that only users, devices, and processes are granted access. Access is allowed to the network before authentication in most networks. Only after connection, the client is authenticated. An attacker could take advantage of this connection to laterally move across devices in the network. Authentication and authorization are concepts which are ideally not breakable, however they can be bypassed with many cyberattacks like brute force, phishing, use of keylogger Trojan virus and so on. We have seen a lot of cyberattacks where attackers bypass the authorization to bring serious damages to the network. Data breach is also a possibility. In such cases, a perimeter defined network can implement a network-based firewall and deny the attacker from connecting to the network. In contrast, the zero-trust model believes that preventing attacks after giving connection would not guarantee total security. A zero-trust architecture does not allow any connection to the network or any application in the network.

In a perimeter defined network, monitoring endpoints is network and human resource intensive. Endpoint monitoring by use of artificial intelligence is not reliable. Identity spoofing and understanding authorization can allow threat actors to bypass the authorization. A zero-trust model believes that the best way to secure a system is by preventing attacks before they occur. This is done by denying suspicious attempts to get in the system based on packet analysis and identity proofing. A network packet analysis can be done in other networks like perimeter defined networks too, however the packet analysis happens at the application layer of the OSI

model. Therefore, it is possible that an intrusion can occur before detection. Software defined perimeter analyses the packets from the end user's context and drops unwanted packets. Those dropped packets are forwarded for analysis. After combining those data with network data, a risk profile can be detected before intrusion. This mechanism in zero trust makes it unique and more secure.

A software defined control pane implements the authorization on each segment of the OSI model. Only after authorization and access control, a device is allowed to access the network. Observing applications is also necessary, which can be local or on the cloud, as they are the software entry point for the network's data. Not only that, endpoint devices like IoT (Internet Of Things) devices at the edge of the network along with their hardware compliance have access to data. Also, the network layer requires protections for assets inside the architecture as well as third party resources. Along with that, infrastructure as certain properties need to be met with concerns of operating system, physical or virtual assets, cloud or local, container and microprocessors. Lastly, the data itself can be structured or unstructured across files and content. With these core layers creating the end to end in Zero trust architecture as malicious threats can target any aspect in these layers, or even ill practice by the users. We can see a simple visual representation of zero trust in [figure 1](#).

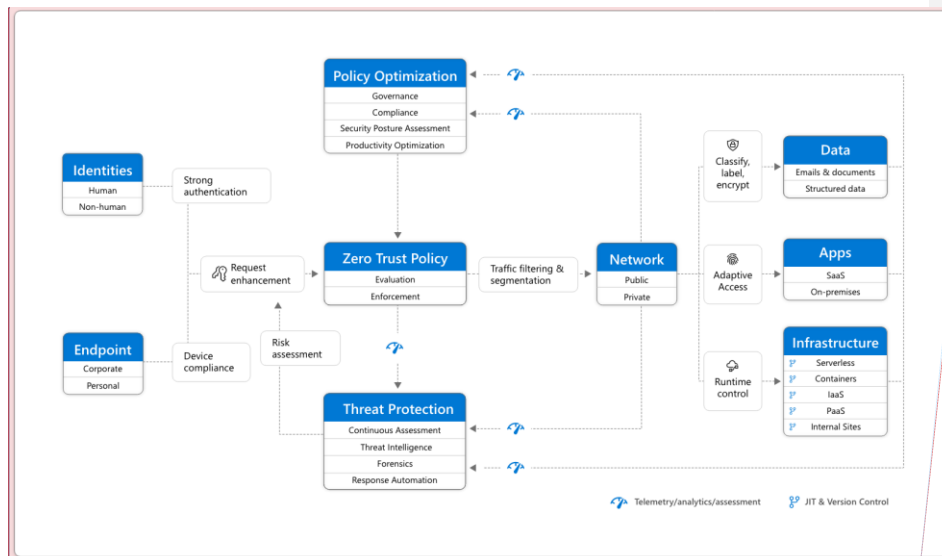


Figure 1: Flow chart on the key layers needed for zero trust [Koipillai]

At present, architectures for Zero Trust are provided in commonly used services like Microsoft Office 365, Azure, and Okta that allow integration of the current running system. For the purpose of this paper, Okta will be further discussed. Okta along with the use of a software

Commented [1]:

Commented [CB2R1]:

defined perimeter shall be used to create a zero-trust model. To clarify, Okta is an independent provider which gives their users integration of Zero Trust for enterprise assets ranging from universal directory, API access management, and access gateways as products that they offer to clients. Okta will allow us to implement identity-based authentication to the users or devices. After authentication through Okta, the user or device can access a particular object on the network. If there are any requests to access other parts of the network, Okta will authenticate those requests every time. This will prevent lateral movement in the network. This prevents a common flaw in most networks, which is allowing access and authenticating. Okta will help us to remove this flaw from our network. [[Okta](#)]

3. Common ways that Zero Trust is implemented

Defining the perimeter of assets that an end to end Zero Trust model can reside in, enforcing policy, granting authentication, and controlling access (refer to figure 1 if needed). The concept of Defense of Depth the separation of applications, services, devices and other assets. Meaning the creation of Security Zones that depends on network architecture, operational requirements, and risk tolerance. These zones can be physical or virtual that can follow protocols and policies created for Zero Trust. Remote Access normally runs off of micro segmentation with end-to-end encryption with TLS or IPsec. It would give access in an isolated zone, only allowing the least privilege needed along with resources required. Leading to network security controls for these defined zones for network layer or tiers that can require domain names such as, @Airline or @NASA for Users and roles, which can be done with the Azure firmware. [[Azure](#)] If the domain is incorrectly configured, then access would be denied before that user entered the architecture. Devices such as, IDS (Intrusion Detection System) and IPS (Intrusion Prevention System) inspect network traffic all the time observing for signs of intrusion, malicious code, exploits, or lateral movement. These devices would be at the threat protection layer and can be configured for active and dynamic actions, remaining idle until activated or continuously running. Informing, where, who, and when the violation of the policies has occurred based on preselected rules. Additionally, these rules can prevent any undefined traffic across zone boundaries, detect and log abnormal activity within zones, log remote access and log legitimate activity to state a few. AWL or application whitelisting will apply a logic of creating a list of good or excepted and blocks anything not on the list. Operating in the application layer, allowing the stoppage and containment of virus or Trojans from penetrating the control system with device application sandboxing. With AWL, the introduction of third-party applications or newly approved applications can be added with defined execution paths for said applications.

4. Security Features of Zero Trust

- Blocks unwanted network connection by using control and data plane of SDN (Software Defined Network)
- Enables protection for cloud-based applications by hiding them
- Denies all users or devices until they are authenticated and authorized
- Provides connection-based security instead of IP-based security, which widens its security perimeter

- Provides an integrated security architecture by integrating user aware applications, client-aware devices and network-aware firewalls/gateways

5. Trust Algorithm

The Trust Algorithm (TA) is the process algorithm in which the Zero Trust architecture follows to classify assets or user's authentication. This algorithm is the core structure where trust is granted based on verification implicitly. The TA, something like a policy engine that either grants access or deny to assets which follows the verify implicitly concept.

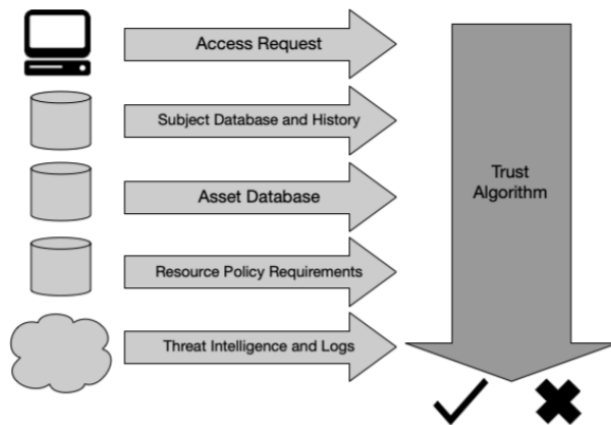


Figure 2 Trust Algorithm as the flow of access is visually represented [Rose]

• **Access request:** This is the request from the subject (User). The resource requested is the primary information used, meaning that for something like log-in would be the property of the request, but information about the requester can also be used. Identity authorization takes place in this layer so that only the verified users' request would be approved. This can include OS version, software used (e.g., Is requesting application on a list of approved applications), and patch level. Depending on these factors and the asset security posture, access to assets might be restricted or denied. [Rose] An example of this layer of defense would be Microsoft Azure's active directory. The active directory holds a list of identity and their corresponding access controls. Not only that, but the active directory has also listed of identities and their web services, applications or processes used and the devices enrolled. Authentication can take place through various strong password authentication methods in this layer.

• **Subject database:** This is the "who" that is requesting access to a resource. It includes a set of subjects (human and processes) of the enterprise or collaborators and collection of subject attributes/privileges assigned, the user's access level like administrator, and their corresponding access control rights. These subjects and attributes form the basis of policies for resource access. User identities can include a mix of logical identity (e.g., account ID) and results of

authentication checks performed by PEPS (Policy Enforcement Point) a system is responsible for enabling, monitoring, and terminating connections between a subject and an enterprise resource. Attributes of identity that can be factored into deriving the confidence level, include time and geolocation. A collection of privileges given to multiple subjects could be thought of as a role, but privileges should be assigned to a subject on an individual basis and not simply because they may fit into a particular role in the organization. This collection should be encoded and stored in an ID management system and policy database. This may also include data about past observed subject behavior in some threat analysis variants. [\[Rose\]](#)

- **Asset database** (and observable status): This is the database that contains the known status of each enterprise-owned (and possibly known non enterprise/BYOD) asset (physical and virtual, to some extent). This is compared to the observable status of the asset making the request and can include OS version, software present, and its integrity, for more information and technical breakdown the, NIST SP 800-207 ZERO TRUST ARCHITECTURE¹⁹ documentation should be reviewed. (<https://doi.org/10.6028/NIST.SP.800-207>location (network location and geolocation)). This layer in TA is dependent on the asset state when compared with this database, access to assets might be restricted or denied. [\[Rose\]](#)

- **Resource requirements:** This is a set of policies that complements the user ID and attributes database and defines the minimal requirements for access to the resource. Requirements may include authentication assurance levels, such as MFA network location (e.g., deny access from overseas IP addresses), data sensitivity, and requests for asset configuration. These requirements should be developed by both the data custodian (i.e., those responsible for the data) and those responsible for the business processes that utilize the data (i.e., those responsible for the mission). [\[Rose\]](#)

- **Threat intelligence:** This is an information feed or feeds about general threats and active malware operating on the internet. Devices such as IDS and IPS would perform their threat management at this layer. This could also include specific information about communication seen from the device that may be suspect (such as queries for possible malware command and control nodes). These feeds can be external services or internal scans and discoveries and can include attack signatures and mitigations. This is the only component that will most likely be under the control of a service rather than the enterprise. Meaning that if a red flag would rise if the policies in action would be broken in the ZTA then a notification would be given and information would be provided via a log with the path of access, who, what they accessed, and when and for how long did they have access. [\[Rose\]](#)

6. Proof of concept

Let's observe implementing Zero Trust architecture on a smart office. This smart office contains tablets, a temperature control system, a smart TV, a door sensor, Air purifier, mobile phones, a printer, workstation (Personal laptop, Desktop), Network Attached Storage, a firewall, a GPU Rack, Network gateway, and Servers/cloud servers. The smart office wants to be able to have teams such as, Security Gateway team and Machine Learning team have secure access. Also, allowing employees that have @spairl.org domain to have access. They also have IPS, IDS, and analytics VNF implemented into the Network security gateway. The issue here is that

with the assets stated, having a secure way to give proper access to administrators versus employees as well as, handling internet connectivity and cloud servers from potential threats becomes a daunting task.

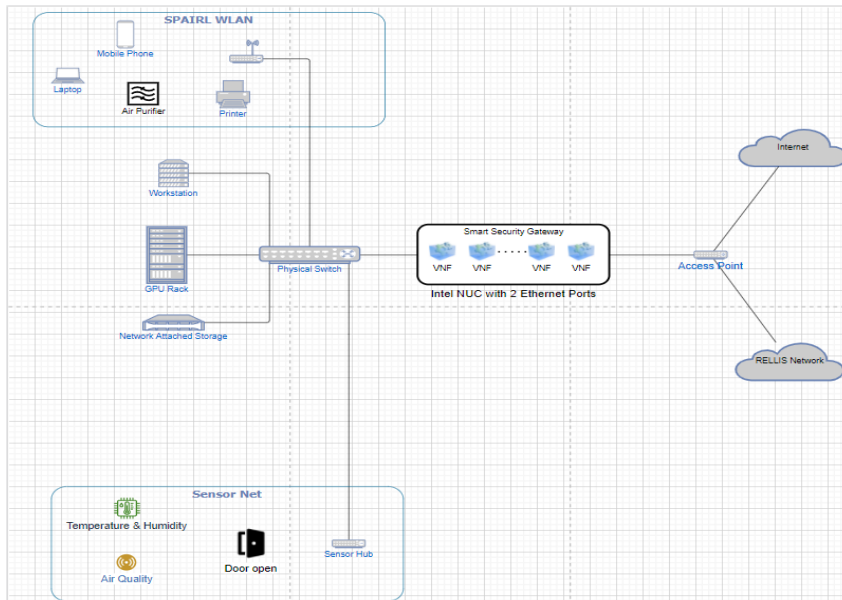
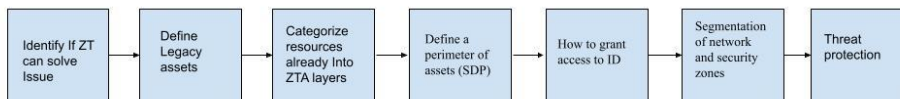


Figure 3 Architecture for Proof of Concept

All the network traffic coming in and going out of the network is going to be encrypted. The first layer of defense in ZT architecture is authorization and authentication. For this purpose, we will be using Okta in our network. Okta provides secure user authentication through its authentication schemes like Single Sign On (SSO). Alongside, Okta is used as an identity management tool to create a database like Azure's active directory which would link identity and their corresponding access controls. This would prevent unauthorized users from accessing the resources. Along with that, this prevents unwanted sharing of sensitive devices, files as well as services to users with less privilege. During sign-on, Okta checks for requests from "@spairl.org" and authenticates them. Okta could be configured to check for requests coming in from a specific workplace. Having multiple branches inside a corporation is highly likely. [Okta] So, teams from the Security Gateway team and Machine Learning team have separate controls of the network. In specific, the controls are defined by the security policy. After Okta, another component exists in the network in the form of a security zone. The intel NUC is a smart security gateway where IPS and IDS will be implemented to create a stronger network perimeter. Network components like load balancers, routers, and firewalls are present in this zone. Nonetheless, monitoring the network constantly helps to quickly detect and respond to the incidents and in some cases reduce the network attacks. Threat detection is one of the important assets in network security, and it is immensely necessary to install the intrusion detection system. In future use, the network data can be collected for threat analysis and using machine learning to

improve the security as well. Then the requests from Okta will securely pass through a tunnel and take it to the specific segment of the network. Network is divided into several segments. Segments are defined as a security zone and different compliance policies are installed in each of the zones. Furthermore, dividing the network into multiple segments is possible in ZT architecture to prevent lateral movement, however in our case the network is divided into two segments. One segment has mobile phone, laptop, air purifier and printer while another segment has sensor networks like temperature and humidity sensor, air quality sensor and door sensor. These are endpoints which would be monitored consistently by IPS and IDS. So even if one zone gets breached, lateral movement is impossible to perform just by known-key attack. Endpoint managers installed on the network shall verify if the endpoints are up-to-date and meet the security compliance policy requirement. This reduces the vulnerability of the network. In fact, the policy installed in intel NUC will require the devices to limit their access to vulnerable software and will not tolerate if the devices have vulnerable settings turned on. Endpoint manager will set the compliance policy in this case. Policy can differentiate data between confidential, top secret, secret and general. Access control lists for users, apps and some services are also defined by the policy. The result will be a zero-trust architecture with this desired result as the goal.

7. Methodology



High demand for hybrid or cloud or sometimes both network infrastructure is one of the popular demands in the networking world. ZT provides a solution for that demand by applying the principle of least privilege and always assuming breach. With ZT you should utilize this concept in private networks. In this process we used a switch, workstation, NAS, GPU rack, an access point and a smart gateway as our networking devices. In addition, integration of a vendor such as Okta, or Azure is necessary with high-cost efficiency in properly integrating ZTA for an enterprise environment.

As such, first identifying if ZT is the proper course of solution for a particular issue should be addressed. In correlation, to identify an issue and with that knowledge stating that the issue is IoT devices, Cloud security, or authentication of identity. Then ZT could be the proper solution for said enterprise.

In correlation with finding that ZT is the correct action for a solution, then knowing what assets are currently implemented in your architecture is key. As stated, internet connectivity will bring risk as it becomes an entity point for threat vectors, therefore, a properly configured firewall or demilitarized zone could be efficient. Yet, the assets like PLC, Server, or PC would need some action taken to aid with pivoting or lateral movement from a threat. If an enterprise

defines what assets are necessary for their day to day functionally or what they already have; employees need a computer, a server is already implemented.

In [figure 1](#), the OSI layer is shown as architecture format hence, the reasoning for defining legacy assets. An enterprise will then group their current assets into data, infrastructure, network, apps, and identity. In addition, to additional assets like a data server, app servers, historians, domain servers, PLC, IDS, or IPS. If an enterprise has or wants a security team, network administrators, or database administrators, then that identity needs to be defined with what resource that identity needs.

With defining a perimeter to the network, a bounty of a closed group of assets is a perimeter. Perimeter defined networks often fail to secure against lateral movement, since once the group of assets has given access to an identity, then it enters the boundaries of trust. However, with ZT that will not be an issue with this architecture. This perimeter is a logical point implemented as a security control between secure and insecure zones. This is a policing of entry to and from zones

In the internal network, segmentation is performed to bring security in the network against lateral movement attacks. Principle of least privilege assures not to give unwanted access to the requests. Many policies need to be set to implement access control. Access controls in many areas like web applications, services, files and allowing control of network devices are important in ZTA. This allows unwanted requests to be blocked and only the authorized requests can get proper service. With this our identity such as, database administrators will be able to have access to the proper resources in the architecture without access to anything else.

Since ZT assumes that a breach would happen anytime, IPS and IDS are installed to analyze network traffic. Threat detection and prevention would be easy after configuring IPS and IDS in the network. Anything that violates the policies in place will be denied access and their actions, entry points, identity used, device information/OS, will be logged for further

investigation. To sum up, building a secure hybrid network infrastructure with ZTA is possible.

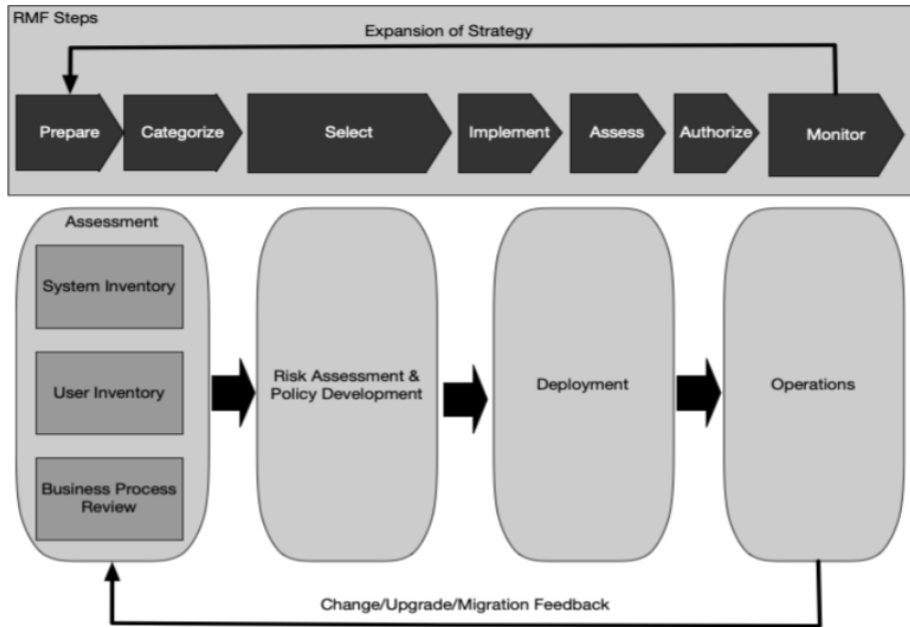


Figure 4 ZTA deployment [Rose]

Hence, a roadmap will be stated at this portion of the paper for clarification. If the test case was to implement zero trust following our methodology presented in the goal of having perimeter security, segmentation, identification, and threat protection for a zero-trust architecture.

Then the enterprise smart office needs to access controls from the Okta vendor, meaning that it has software that will classify roles of Security Gateway team and Machine Learning team as well as a PLC device that will handle the policy controls for the trust algorithm. Note that this device can be configured to add new devices, applications and policies. Also, the need for a whitelist software such as, manageEngine; will the requirement of more servers such as a data server, application server, and network server. These zones should be documented as an ongoing security for identifying what systems can be accessed by another system. To allow for network segmentation with least privilege in a sandbox environment. Hence, if policies are broken then entry point, OS, credentials used, and timestamped logs can aid understanding the issue that occurred at the threat protection layer with IDS, and IPS. With this method of a sandbox environment for assets, then threats cannot destroy enterprise assets.

In [figure 4](#) above is the ZTA deployment chain to further iterate what this paper explains on implementation. The RMF steps and the change/upgrade/migration feedback is to aid an enterprise in the addition of new assets and processes the future may hold. ZTA requires knowledge of assets, processes, and subjects for functionally, updating, and implantation.

8. Conclusions

A secure network architecture is essential to keep data secure for any company. Data breach is very risky and exposes companies to huge consequences. From this paper, we can conclude that hybrid architecture can be built with Zero Trust as its backbone. ZTA will provide a secure architecture which will prevent many network threats from preventing access to the network. This paper provided an insight to zero trust and a brief example of implementing it in a network. It showed the trust algorithm and scope of the zero trust and how it could solve the problem of perimeter defined security.

9. Recommendations

Perimeter security is similar to zero trust architecture, so understanding the main difference between perimeter security and zero trust security was a challenge for us. In addition, the creating a baseline methodology for zero trust architecture founded on implementation of the test case smart office.

10. References

[Koilpillai]

Juanita Koilpillai and Nya Alison Murray. Software-Defined Perimeter (SDP) and Zero Trust | CSA. <https://cloudsecurityalliance.org>. Retrieved June 1, 2022 from <https://cloudsecurityalliance.org/artifacts/software-defined-perimeter-and-zero-trust/>

[Rose]

Scott Rose, Oliver Borchert, Stu Mitchell, and Sean Connelly. 2020. Zero Trust Architecture. *NIST SP* (2020). DOI:<https://doi.org/10.6028/nist.sp.800-207>

[Okta]

Security Technical White Paper | Okta. *Okta*. Retrieved June 4, 2022 from <https://www.okta.com/resources/whitepaper/okta-security-technical-white-paper/>

[Grassi]

Paul A Grassi, Michael E Garcia, and James L Fenton. 2017. Digital identity guidelines: revision 3. (2017). DOI:<https://doi.org/10.6028/nist.sp.800-63-3>

[Azure]

2022. Shared responsibility in the cloud - Microsoft Azure | Microsoft Docs. *Microsoft Build*. Retrieved February 26, 2022 from <https://docs.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility>

[Rose, Draft]

Scott Rose. 2021. Draft NIST Cybersecurity White Paper, Planning for a Zero Trust . Retrieved April 5, 2022 from <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.08042021-draft.pdf>